

Checklist Tuân thủ ISO/IEC 27001

Mã tài liệu: CHK-COMP-004 | Phiên bản: 1.1 | Nội bộ hạn chế

Danh sách kiểm tra nội bộ dùng để tự đánh giá mức độ sẵn sàng trước khi đánh giá chứng nhận ISO/IEC 27001 chính thức. Chỉ dành cho Security Manager và Admin sử dụng trong quá trình chuẩn bị audit.

A.5 - Chính sách bảo mật thông tin

- ☐ Đã ban hành chính sách ATTT được lãnh đạo phê duyệt
- ☐ Chính sách được rà soát lại trong 12 tháng gần nhất

A.9 - Kiểm soát truy cập

- ☐ Có quy trình cấp/thu hồi quyền truy cập bằng văn bản
- ☐ Đã triển khai MFA cho tài khoản đặc quyền
- ☐ Có nhật ký (log) truy cập được lưu trữ tối thiểu 6 tháng

A.12 - Bảo mật vận hành

- ☐ Có quy trình quản lý thay đổi hệ thống (change management)
- ☐ Có giải pháp chống mã độc trên toàn bộ endpoint
- ☐ Có kế hoạch sao lưu và đã kiểm thử khôi phục dữ liệu

A.16 - Quản lý sự cố an toàn thông tin

- ☐ Có quy trình ứng phó sự cố bằng văn bản (xem PROC-IR-002)
- ☐ Đội ứng phó sự cố đã được đào tạo trong 12 tháng gần nhất